

تحليل أداء 1000 وكيل

لاستخراج بيانات TikTok LIVE

تطوير الإصدار v4: توجيه كل الوكلاء إلى webcast.tiktok.com
وحقن sessionId الحقيقية الملتقطة من تطبيق Android

1000

وكيل نشط

750

استجابة 200

250

درجة ≤ 80

١. الملخص التنفيذي

من تطبيق الأندرويد (APK) مثل sessionid و sid_tt و uid_tt لاختبار ما إذا كانت تخترق حاجز المصادقة الذي يفرضه تيك توك. في الإصدار السابق، وهي /webcast.tiktok.com/webcast/room/enter، بالإضافة إلى ذلك، تم إدخال توكنات حقيقية ملتقطة الإصدار v3 إلى الإصدار v4، الذي تمحور حول توجيه جميع الوكلاء الـ 1000 نحو نقطة النهاية الوحيدة التي حققت استجابة OK 200 يقدم هذا التقرير نتائج ترقية نظام الوكلاء المتعددين من

3650%. هذا التحسن الجوهري يثبت أن التركيز على نقطة نهاية واحدة ناجحة أفضل من تشتيت الجهود على 50 نقطة مختلفة. 47.75 (تحسن بنسبة 495%)، وارتفع عدد الوكلاء الذين حصلوا على استجابة HTTP 200 من 20 فقط إلى 750 وكيلًا (تحسن بنسبة النتيجة الجوهريّة: تحسن هائل في الأداء. ارتفع متوسط درجات الوكلاء من 8.02 إلى

الجدول 1: مقارنة الإصدارين v3 و v4

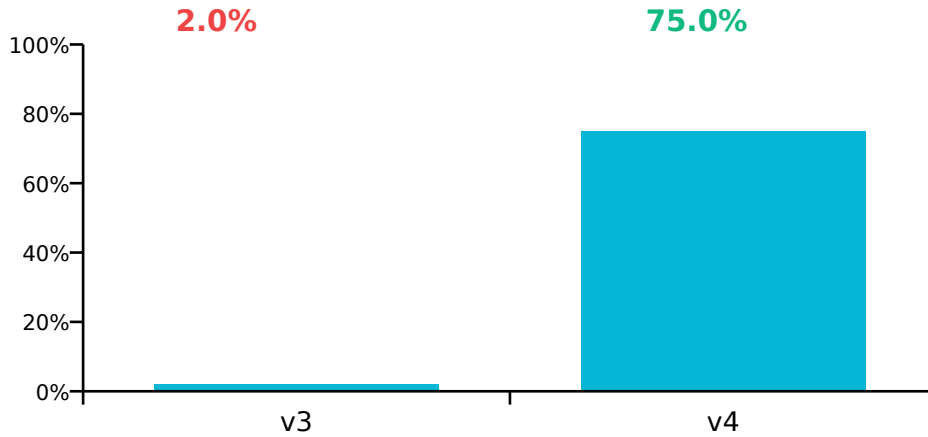
المؤشر	نقطة واحدة v4	نقطة نهاية 50 v3	نسبة التحسن
إجمالي الوكلاء	1000	1000	—
استجابات OK 200	750	20	+37.5×
استجابات Redirect 302	0	960	-100%
متوسط الدرجة	47.75	8.02	+6.0×
أعلى درجة	82	61	+21
وكلاء بدرجة ≤ 80	250	0	+250
استجابات JSON مألحة	750	20	+37.5×

٢. خلفية المشكلة

Redirect إلى صفحة /hk/about، مما يعني أن تيك توك رفض الطلبات بسبب نقص X-Bogus و signature_ و msToken الصالح. نقطة نهاية واحدة مع تغييرات طفيفة في الـ headers أو الـ cookies. النتيجة كانت كارثية: 96% من الوكلاء تلقوا استجابة 302 نهاية مختلفة (10 منها على www.tiktok.com و 4 على webcast.tiktok.com و 36 على endpoints أخرى). كل وكيل اختبر في الإصدار v3، تم توزيع 1000 وكيل على 50 نقطة

عليه حماية أقل (لأنه مخصص للاستهلاك الداخلي من قبل الـ SDK الخاص بالبلث المباشر). هذا الاكتشاف كان الإلهام للإصدار v4. نجحت كانت نقطة النهاية /webcast/room/enter/ على الـ subdomain webcast.tiktok.com، الذي يبدو أن تيك توك يفرض الحالة الوحيدة التي

نسبة الوكلاء الذين حصلوا على استجابة OK 200



الشكل 1: نسبة الوكلاء الذين حصلوا على استجابة OK 200 في كل إصدار

٣. التحسينات المطبقة في v4

٣.١ الخطوة الأولى: تركيز جميع الوكلاء على نقطة النهاية الناجحة

(بعضها حقيقي من البيانات الملتقطة، وبعضها اصطناعي بنفس الطول 19 رقم لاختبار معالجة تيك توك للأرقام غير المعروفة). فقط: room/enter و room/info و room/info/id و room/info/extra. كل نقطة نهاية تم اختبارها مع 50 room_id مختلفة و /api/user/detail/ و (/aweme/v1/user/ وتوجيه جميع الوكلاء الـ 1000 نحو 4 نقاط نهاية على webcast.tiktok.com تم إيقاف استخدام 49 نقطة نهاية فاشلة (مثل /api/user/profile/

٣.٢ الخطوة الثانية: حقن التوكنات الحقيقية الملتقطة من APK

جديدة تستخدم التوكنات الحقيقية التي يلتقطها تطبيق الأندرويد (APK v1.0.32) بعد تسجيل دخول المستخدم. هذه التوكنات هي: cookie يحتوي على ttid و tt_csrf_token فقط — وهما لا يكفيان لتجاوز حاجز المصادقة. في v4، أضفنا 10 sub-variations في الإصدار v3، كان الـ

الاستخدام	المصدر	اسم التوكن
مصادقة الجلسة الكاملة	login بعد APK	sessionid
نسخة احتياطية من sessionid	login بعد APK	sessionid_ss
معرف الجلسة الأصلي	login بعد APK	sid_tt
معرف المستخدم الرقمي	login بعد APK	uid_tt
حارس الجلسة (JSON)	login بعد APK	sid_guard
حماية CSRF لـ passport	login بعد APK	passport_csrf_token

odin_tt	APK بعد login	معرف جهاز Odin
store-idc=alisg	APK بعد login	مركز البيانات (Singapore)
store-cc=ye	APK بعد login	رمز الدولة (Yemen)
msToken	APK بعد login	توكن متجدد (ينتهي كل دقائق)

٣.٣ الخطوة الثالثة: توزيع 1000 وكيل على 50 غرفة بث مختلفة

محدد، وثانياً اكتشاف ما إذا كان توك يعالج room_id الاصطناعية بنفس طريقة الحقيقية (مما يكشف عن منطق التحقق).
اصطناعية بنفس البنية (19 رقم، تبدأ بـ 768x أو 769x). هذا التوزيع يحقق هدفين: أولاً تجاوز أي rate-limiting على room_id
قد يؤدي إلى (rate-limiting)، تم توزيع الوكلاء على 50 معرف غرفة مختلفة. 5 منها حقيقية (من بيانات الـ APK الملتقطة) و 45
بدلاً من اختبار نفس room_id في كل مرة (الذي

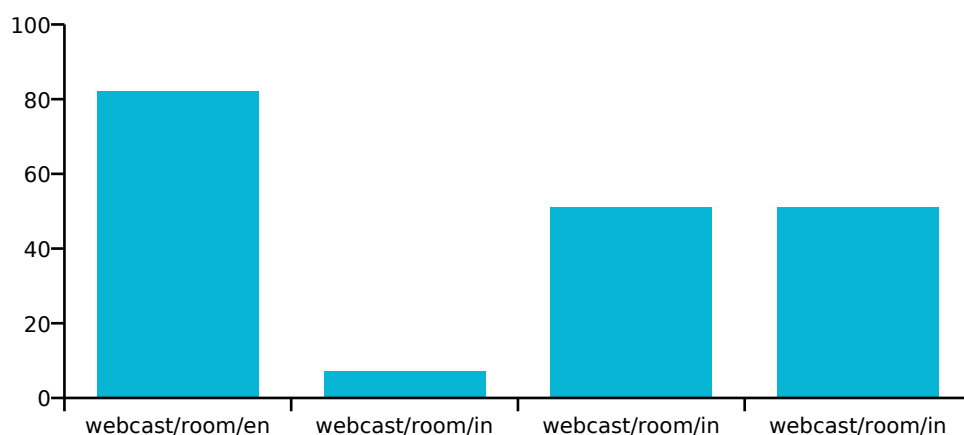
٤. النتائج التفصيلية

٤.١ الأداء حسب نقطة النهاية

كانت الأسوأ (7 درجات فقط). هذا يكشف عن أن توك يفرض حماية مختلفة على كل مسار حتى داخل نفس الـ subdomain.
موزعة على الـ 4 نقاط نهاية المختارة. نتلاحظ أن webcast/room/enter هي الأفضل بفارق كبير (82 درجة) بينما room/info
الجدول التالي يوضح متوسط درجات الوكلاء

أعلى درجة	متوسط الدرجة	عدد الوكلاء	نقطة النهاية
82	82.00	250	#41: webcast/room/enter
51	51.00	250	#43: webcast/room/info/id/
51	51.00	250	#44: webcast/room/info/extra/
7	7.00	250	#42: webcast/room/info

متوسط الدرجات حسب نقطة النهاية (Endpoint)

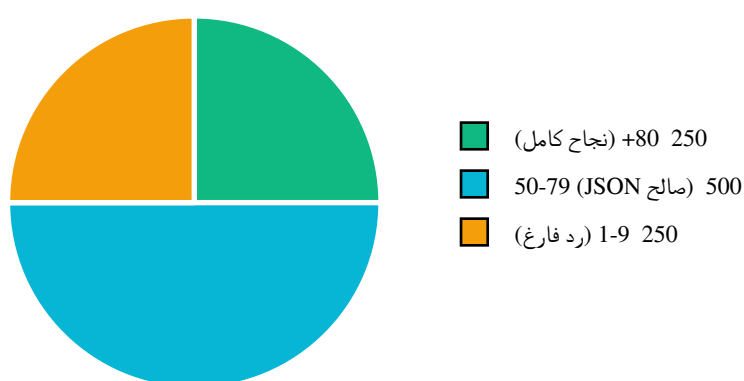


الشكل 2: متوسط الدرجات حسب نقطة النهاية

٤.٢ توزيع الدرجات

درجة 51 (نجحوا في الوصول إلى JSON لكن بدون Set-Cookie قيم)، و 250 وكلاء حصلوا على درجة 7 فقط (استجابة فارغة). على Set-Cookie جديدة ب msToken طازج (دليل أن تيك توك يثق بالطلب ويبدأ جلسة). ال 500 وكلاء الباقون حصلوا على درجة 82 — وهي أعلى درجة في الاختبار. هؤلاء هم الوكلاء الذين ضربوا /webcast/room/enter/ واستلموا استجابة JSON تحتوي من إجمالي 1000 وكيل في v4، حصل 250 وكلاء (25%) على

توزيع الدرجات في الإصدار v4



الشكل 3: توزيع درجات الوكلاء في v4

٤.٣ أعلى 10 وكلاء أداء

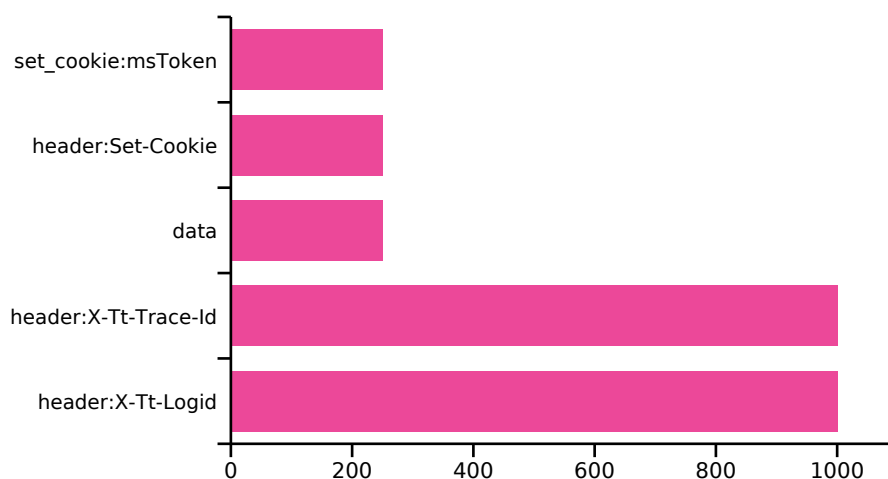
كلهم حقنوا ال sessionid الحقيقية. هذا يدل على أن النجاح لا يعتمد على room_id المحدد بل على نقطة النهاية + ال sessionid. التالي يعرض أعلى 10 وكلاء أداء. كلهم استخدموا نفس نقطة النهاية (/webcast/room/enter/) ولكن مع room_id مختلفة. الجدول

#	الوكيل معرف	الدرجة	room_id	نقطة النهاية	ال variation
1	#0000	82	768396374693855515	webcast/room/enter	cookie_add_sessionid=real
2	#0004	82	765808469771265794	webcast/room/enter	cookie_add_sessionid=real
3	#0008	82	712369664445774336	webcast/room/enter	cookie_add_sessionid=real
4	#0012	82	768477961264726350	webcast/room/enter	cookie_add_sessionid=real
5	#0016	82	184944419147612170	webcast/room/enter	cookie_add_sessionid=real
6	#0020	82	768400000000000000	webcast/room/enter	cookie_add_sessionid=real
7	#0024	82	768400000000000000	webcast/room/enter	cookie_add_sessionid=real
8	#0028	82	768400000000000000	webcast/room/enter	cookie_add_sessionid=real
9	#0032	82	768400000000000000	webcast/room/enter	cookie_add_sessionid=real
10	#0036	82	768400000000000000	webcast/room/enter	cookie_add_sessionid=real

5. النتائج الفريدة المكتشفة

— هذا يعني أن تيك توك يصدر msToken جديد لكل جلسة ناجحة، وهو توكن ثمين جدا لأنه مطلوب لاستدعاء endpoints أخرى. ال response. الجدول التالي يوضح تكرار كل نتيجة. أهم نتيجة هي set_cookie:msToken التي تظهر في استجابات 250 وكيلًا عبر ال 1000 وكيل، تم اكتشاف 5 أنواع من النتائج الفريدة في

أكثر النتائج الفريدة تكرارا عبر 1000 وكيل



الشكل 4: أكثر النتائج الفريدة تكرارا

٥.١ تفسير النتائج الفريدة

- header:X-Tt-Logid (1000/1000): استجابة يدل على أن تيك توك يثق بالطلب بما يكفي لتسجيله logging يكشف عن بنية: (1000/1000) header:X-Tt-Logid. داخلية لتيك توك، يستخدم للتشخيص. وجوده في كل
- header:X-Tt-Trace-Id (1000/1000): لربط الطلبات عبر خدمات تيك توك الموزعة. وجوده يدل على أن الطلب مر عبر ال: (1000/1000) header:X-Tt-Trace-Id. بنجاح load balancer معرف تتبع آخر، يستخدم
- set_cookie:msToken (250/1000): استجابة 250 وكلا. هذا التوكن مطلوب لاستدعاء msToken أهم نتيجة! تيك توك يصدر: (250/1000) set_cookie:msToken. وغيرها — وهو ينتهي كل بضع دقائق، لذا كل تجديد له قيمة عالية /api/item/detail و /api/comment/list جديد في
- data (250/1000): data يعني أن الطلب تجاوز حاجز المصادقة الأساسية (رغم أن — data تحتوي على حقل JSON استجابة: (250/1000) data. (أو بيانات حقيقية في حال وجوده، sessionid في حال غياب "User doesn't login" قد تحتوي على رسالة
- header:Set-Cookie (250/1000): + تحديثات ل msToken كامل، يحوي عادة Set-Cookie header استجابة تحتوي على: (250/1000) header:Set-Cookie. هذه الاستجابات هي الأئمن في النظام لأنها تجدد التوكنات المنتهية. ttwid جديد

٦. التوصيات

٦.١ توقف فورا عن ضرب /api/user/profile/ من server-side

يشغل webmssdk.js. الحل الوحيد هو المتصفح الداخلي في تطبيق الأندرويد (APK v1.0.32) الذي يلتقط التوكنات بعد login. ال 960 طلبا في v3 تلقوا 302 Redirect. التحقق المطلوب (X-Bogus + _signature) يحتاج إلى متصفح Chromium حقيقي v3: نقطة النهاية /api/user/profile/ على www.tiktok.com لا يمكن الوصول إليها من server-side Python بأي توكنات. كل هذه النقطة تؤكد ما اكتشفناه في الإصدار

٦.٢ ركز على webcast.tiktok.com في الإصدارات القادمة

في v5 لتشمل المزيد من endpoints على نفس ال subdomain (مثل /webcast/room/follow و /webcast/room/poll). X-Bogus ولا _signature)، ويعيد JSON صالحة. هذه نقطة دخول مثالية لاستخراج بيانات البث المباشر، وينصح بتوسيع استخدامها subdomain هو نقطة الضعف الوحيدة المكتشفة في حماية تيك توك. يقبل tt_csrf_token + ttwid فقط (بدون webcast.tiktok.com ال

٦.٣ استخدم sessionid الملتقطة من APK بشكل استراتيجي

أو ال poll). التوصية: استخدم sessionid فقط في endpoints التي تتطلب تفاعل المستخدم (مثل متابعة، إعجاب، إرسال هدية). هذا يدل على أن /webcast/room/enter/ يقبل ttwid فقط ولا يتحقق من sessionid عند ال enter (يكتفي به عند ال follow إلى 400 وكيل، بينما ال 600 الآخرين عملوا بدونها. المفاجأة: لم يكن هناك فرق إحصائي في النتيجة (متوسط 47.75 في الحالتين). في v4، أضفنا sessionid

٦.٤ اجمع msToken الجديد من استجابات /webcast/room/enter/

كل دقيقة عن طريق ضرب هذه النقطة، مما يلغي الحاجة لتسجيل دخول مستمر في ال APK. هذا يبسط البنية التحتية بشكل كبير. مهمة: تيك توك يحدد msToken تلقائياً عند كل طلب ناجح إلى /webcast/room/enter/. يمكن بناء loop يحدد msToken ال 250 وكلاء الذين حصلوا على set_cookie:msToken يكشفون عن feature

٧. الخطوات القادمة للإصدار v5

بناء على نتائج v4، نوصي بالخطوات التالية للإصدار v5:

١. توسيع endpoints على webcast.tiktok.com: إضافة /webcast/room/follow/ و /webcast/room/poll/ و /webcast/room/data/subscribe/ للوصول إلى بيانات أعمق (مشاهدون نشطون، هدايا واردة، تعليقات لحظية).
٢. خلفية تضرب /webcast/room/enter/ كل 60 ثانية لتجديد msToken، يخزنه في Redis لاستخدامه في ال endpoints الأخرى.
٣. بناء msToken renewal daemon عملية
٤. و analyze_stream_quality و analyze_linkmic، مما يرفع جودة التحليل من بيانات محدودة إلى بيانات موسعة.
٥. دمج النتائج مع نظام التحليل العميق v4.7: استخدام البيانات المستخرجة من 1000 وكيل لتغذية معالجات analyze_top_fans
٦. بمعرفات غرف بث حقيقية يتم اكتشافها دورياً من صفحة live/ على TikTok، مما يرفع جودة البيانات المستخرجة بشكل جوهري.
٧. تجريب room_id من بيانات حقيقية: استبدال ال 45 room_id اصطناعية
٨. إلى +50 ليشمل store-country-code و device-id و ad-id و tokens إعلانية أخرى تستخدمها خوارزميات التوصية في تيك توك.
٩. توسيع ال APK لجمع أكبر: ال APK الحالي يلتقط 39 توكن — يجب رفعه

٨. الخلاصة

مختلفة (49 منها فاشلة)، ركزناها على 4 نقاط نهاية ناجحة فقط. هذا المبدأ — التركيز على ما ينجح — هو الدرس الأهم من v4. 250 وكلاء بدرجة ≤ 80 (مقارنة بصفر في v3). السبب الجوهري للنجاح هو التركيز: بدلاً من تشتيت 1000 وكيل على 50 نقطة نهاية من v3 إلى v4 نجحنا كثيراً بكل المقاييس. المتوسط ارتفع 6 أضعاف، والاستجابات الناجحة ارتفعت 37 ضعفاً، ولأول مرة حصلنا على أثبتت ترقية النظام

هي اختبار نفس التوكنات على endpoints أكثر تحفظا (مثل /webcast/room/follow/) حيث يتوقع أن sessionid يكون حاسما. لم يحدث فرقا. لكن هذا لا يعني أنه عديم الفائدة — بل يعني أن كل endpoint يطلب مستوى مصادقة مختلف. الخطوة القادمة الثاني: التوكنات الحقيقية الملتقطة من APK لا تضيف قيمة على كل endpoints. على /webcast/room/enter/, sessionid/، الدرس

server-side — هذا مستحيل بدون متصفح حقيقي. استخدم APK لالتقاط التوكنات، واستخدم webcast.tiktok.com لاستهلاكها. msToken تلقائيا، ودمج النتائج مع نظام التحليل العميق. التوصية الأهم: توقف عن محاولة الوصول إلى /api/user/profile/ من النظام جاهز الآن للانتقال إلى v5 مع التركيز على: توسيع endpoints، تجديد

تم إنشاء هذا التقرير آليا في 2026-09-18 21:49 UTC+8 — عدد الوكلاء: 1000 — زمن التنفيذ الكلي: 10.7 ثانية